

[文章总结]

本文主要关注 DNS 基础设施劫持攻击，这种攻击首先是攻击者通过控制目标域名的 DNS 配置，然后获取合法的 TLS 证书，进而劫持流量到伪造服务以窃取用户信息。这种攻击自 2013 年被发现后就持续存在，但由于其持续时间短、隐蔽性强的特点，现有的传统检测手段难以及时发现，也难以进行事后追溯。

基于上述攻击流程，论文提出了一套基于公开互联网测量数据的事后识别方法：首先利用 Censys 等数据构建域名的部署图谱，按时间聚类获得到的 IP、ASN、证书信息；其次将部署模式分为为稳定、过渡与瞬态，重点将短暂出现且与稳定部署显著不同的瞬态视为可疑的部署；随后应用启发式规则筛选与合法基础设施相关的噪声，并对剩余图谱结合被动 DNS 与证书透明日志进行人工复核；最后以确认的攻击者 IP 或 nameserver 为枢纽，扩展发现其它受害域名。

本文的贡献在于无需受害者配合即可发现受害域名及其攻击基础设施。通过对每个域名构建部署图谱，识别出三种不同的部署模式，重点关注其中的瞬态部署模式，这种模式极大可能与伪造攻击的基础设施相关。最后通过多源数据的融合分析，提出一个可复现且针对性强的识别框架，用以检测难以发现的 DNS 劫持攻击。

[优缺点分析]

优点：

1. 与现有传统识别方案不同，本文并非直接监测短暂的 DNS 记录更改，而是主要关注攻击者搭建的伪造基础设施，并以此来识别和追溯 DNS 基础设施劫持攻击，给后续研究提供了新思路。
2. 基于公开且权威的互联网测量数据源（如 Censys、CAIDA 等），本文从攻击模型出发，基于完整的部署图谱，构建了一套检测系统。此外，通过与公开的 Sea Turtle 攻击报告进行对比，进一步验证了方法的有效性，并发现了一些此前未被披露的攻击案例。

缺点：

1. 目前的系统还是无法覆盖所有 DNS 劫持攻击，尤其是那些未被扫描或记录的短暂劫持。并且由于时间粒度有限，可能错过持续时间极短的攻击。
2. 在前期筛选先进行自动化处理，但最终仍需要人工判定，这在一定程度上限制了在大规模与实时场景中的应用。此外，研究只考虑了 IPv4 地址空间，若后续出现针对 IPv6 地址空间的攻击，该方法的鲁棒性与适用性将需要进一步验证。

[问题与思考]

Q1：如果攻击者使用私有 CA 颁发的证书（非浏览器信任）或者直接不使用证书（通过社会工程学），该方法将完全失效。

A1：对于这些使用不合法证书的情况，我们可以结合其他侧信道的方法，如 BGP 路由变化、Whois 记录变化来进一步识别。

Q2：论文提到有 77K (0.35%) 的域名因部署不稳定而被排除。这部分域名中可能隐藏着高度复杂、试图通过频繁切换基础设施来逃避检测的攻击。

A2：虽然攻击者会频繁切换基础设施，但其攻击的步骤和时间序列模式是相对固定的，应识别出攻击者的固有模型，进一步细化改进模型，以处理这类恶意行为。

[评论]

我认为这篇论文的比较好的地方在于，它打破了传统研究中对受害者的依赖，转而利用公开互联网测量数据（如扫描数据、被动 DNS、证书透明日志）实现事后识别。这种方法说明即使在缺乏受害者配合的情况下，研究人员仍能通过现有数据关联并识别攻击事件。

不过从研究方法上看，这项工作仍存在一些值得改进的地方。例如，它依赖的公开数据粒度有限，难以捕获持续时间极短的攻击；此外，论文中提到的“manual qualitative evaluation”说明目前自动化程度仍然较低，在后续的研究中可以进一步优化。总体而言，我认为这篇论文很不错，不仅在方法上具有创新性，在相关写作方法上也值得参考学习。